

Orvion.co — Engineering Audit Report

Project: saral-banker-portfolio (folder: orivon) **Type:** Client-only static marketing/portfolio SPA **Stack:** React 19 · TanStack Router · Vite 7 · Tailwind 4 · GSAP · Framer Motion · Lenis · Vercel **Audit date:** 2026-06-26
Method: Static source review + TypeScript compile (`tsc --noEmit` → 0 errors) + repo/grep inspection. **NOT run:** live Lighthouse, real-device/browser matrix, runtime profiling. Such findings are labeled *Likely / Possible*, never *Verified*.

0. Scope & Reality Check

This is a **static client-side site**. There is **no backend, no database, no real authentication, no payments, no file upload, no API**. So entire classes of risk (SQLi, SSRF, IDOR, CSRF, JWT, payment security) **have no attack surface here** and are marked *Not Applicable* rather than invented.

The real risks are: a **fake login shipping hardcoded credentials, SEO gaps, missing security headers, no social preview image, zero tests, repo hygiene**, and a **brand-name typo**.

1. Executive Summary

The code is **clean, modern, and fully type-safe**. Engineering taste is high — accessibility skip-link, reduced-motion handling, graceful error boundary, thoughtful comments. Above typical portfolio quality.

But it is **not production-hardened**:

- Fake client-side login ships **hardcoded credentials** (`admin / 1234`), and the error message prints them to every visitor.
- **Per-page SEO exists only on the home page** — 6 other routes share one static `<title>` .
- **No security headers** (`vercel.json` only rewrites) → clickjacking possible.
- **No `og:image`** → blank social-share cards.
- **Zero automated tests** (`playwright` installed but unused).
- **Repo junk committed** under `reports/` (Excel lock files, one-off scripts, a screenshot).
- **Brand typo:** brand is "Orvion" everywhere, but the resume is `Orivon_Team_Resume.pdf` .

Only one launch blocker: remove/gate the fake login.

2. Scorecard

Dimension	Score	Basis
Overall Production Readiness	68 / 100	Solid frontend; SEO/headers/tests gaps
Security	60 / 100	No real attack surface, but hardcoded creds + no headers
Performance	70 / 100	<i>Likely</i> heavy (GSAP+Framer+Lenis+canvas); not measured
Accessibility	72 / 100	Skip link + reduced-motion present; custom cursor/magnetic risks
SEO	45 / 100	Home-only meta, relative canonical, no og:image, no sitemap
UX	82 / 100	Strong visual craft; contact flow has data-loss edge cases
Maintainability	80 / 100	Type-safe, modular; repo junk drags it down
Scalability	N/A	Static CDN assets scale trivially
Test Coverage (est.)	~0%	No project test/spec files exist

3. Findings by Priority

● P0 — Launch Blocker

P0-1 — Fake auth ships hardcoded credentials in the client bundle

- **Severity:** Critical (in-context: High) · **Confidence:** 100% · **Verified**
- **Evidence:** `src/routes/login.tsx:22`

```
if (username === "admin" && password === "1234") {  
  localStorage.setItem("portfolio_auth", "1");  
} else {  
  setError("Invalid credentials. Try admin / 1234."); // leaks the creds  
}
```

- **Why it matters:** Credentials are compiled into the JS and the error string discloses them. `localStorage` is no security boundary (anyone can set the flag in DevTools). A studio that sells engineering credibility shipping `admin/1234` is self-defeating.
- **Fix:** Delete the `/login` route + `sign-in-card` entirely (nothing in the app is gated by it), or wire a real backend. At minimum remove the credential hint.
- **Effort:** 15 min · **Regression risk:** Low

● P1 — High

P1-1 — Per-page SEO missing on 6 of 7 routes

- **Confidence:** 95% · **Verified**
- **Evidence:** `<SEO>` rendered only in `src/routes/index.tsx:16,56`. `about`, `work`, `work.$slug`, `pricing`, `contact`, `process`, `login` emit no `<title>` / `<meta>` / `canonical` — they inherit the static `index.html` title.

- **Impact:** Duplicate titles/descriptions across all deep pages; case-study pages (`/work/:slug`) are undifferentiated in search.
- **Fix:** Add `<SEO>` (or TanStack Router `head`) to every route with unique title/description/canonical; derive `/work/:slug` from project data.
- **Effort:** 2–3 h

P1-2 — No security headers

- **Confidence:** 100% · **Verified**
- **Evidence:** `vercel.json` has only a SPA rewrite — no `headers` block.
- **Impact:** No `X-Frame-Options` /CSP `frame-ancestors` → clickjacking. Missing `nosniff` , `Referrer-Policy` , `Permissions-Policy` , `HSTS` .
- **Fix:**

```
{
  "headers": [{
    "source": "/*.*",
    "headers": [
      { "key": "X-Frame-Options", "value": "DENY" },
      { "key": "X-Content-Type-Options", "value": "nosniff" },
      { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
      { "key": "Permissions-Policy", "value": "camera=(), microphone=(), geolocation=()" },
      { "key": "Strict-Transport-Security", "value": "max-age=63072000; includeSubDomains; preload" }
    ]
  }]
}
```

- **Effort:** 1–2 h · **Regression risk:** Medium (add CSP last, report-only first — inline theme script + Google Fonts + JSON-LD)

P1-3 — No `og:image` → broken social previews

- **Confidence:** 95% · **Verified**
- **Evidence:** `SEO.tsx` supports `ogImage` but it is never passed; `index.html` declares `twitter:card=summary_large_image` with no image.
- **Fix:** Add a 1200×630 OG image to `/public` ; set a default `ogImage` in `SEO` and `index.html` .
- **Effort:** 1 h

P1-4 — Zero automated tests

- **Confidence:** 100% · **Verified**
- **Evidence:** No `*.test.*` / `*.spec.*` outside `node_modules` ; `playwright` is a dep but unused; no `test` script.
- **Fix:** Start with 3 Playwright smoke tests (each route renders, no console errors, contact form opens compose).

● P2 — Medium

ID	Finding	Evidence	Fix	Effort
P2-1	Relative canonical "/" (must be absolute)	<code>index.tsx:59</code>	Emit absolute <code>https://orvion.co/...</code>	30 min
P2-2	No <code>sitemap.xml</code> ; robots doesn't reference one	<code>public/robots.txt</code>	Generate sitemap at build + add <code>Sitemap:</code> line	1 h
P2-3	Brand typo: resume is <code>Orivon_Team_Resume.pdf</code> vs brand "Orvion"	<code>CinematicHero.tsx:381</code>	Rename asset + href to <code>Orvion_...</code>	15 min
P2-4	Contact form has no real backend; lead lost if popup blocked / no mail client	<code>contact.tsx:227</code>	Add serverless/Formspre/Resend endpoint as primary, compose as fallback	3–4 h
P2-5	3 personal Gmail addresses in plaintext (spam scraping)	<code>contact.tsx:144–148</code>	Route through backend form / obfuscate	(with P2-4)
P2-6	Repo junk committed: <code>~\$*.xlsx</code> lock files, <code>check4.mjs</code> , <code>build-pdfs.mjs</code> , <code>excel-data.json</code> , <code>final-pricing-check.png</code>	<code>git ls-files reports/</code>	<code>.gitignore</code> + <code>git rm --cached</code>	20 min

P3 — Low

- **P3-1** `index.html:19` author meta inconsistent with org-first branding. *Verified.*
- **P3-2** Inline theme bootstrap only sets `dark` ; *Likely* light-mode FOUC. *Not verified at runtime.*
- **P3-3** `defaultPreloadStaleTime: 0` (`router.tsx:69`) → intent-preloads never cached fresh. *Verified config, Possible perf nit.*
- **P3-4** `/login` is `Disallow` 'd in robots but still ships JS (ties to P0-1). *Verified.*

4. Security Review (OWASP-oriented)

Class	Status
XSS	None found — contact body is <code>encodeURIComponent</code> 'd (<code>mail.ts:53–55</code>); JSON-LD uses <code>JSON.stringify</code> on object literals (no user input).
<code>target="_blank"</code> safety	✅ contact links use <code>rel="noopener noreferrer"</code> .
Hardcoded secrets	❌ <code>admin/1234</code> (P0-1).
Security headers	❌ missing (P1-2).
SQLi / SSRF / IDOR / CSRF / JWT / file upload / GraphQL	N/A — no server, cookies, or APIs (verified by absence).
Sensitive data exposure	⚠️ personal emails in plaintext (P2-5).

5. Performance Notes (Likely — not measured)

- Three+ animation systems: GSAP+ScrollTrigger, Framer Motion, Lenis, plus `<CinematicHero>` canvas + `InteractiveParticles2D` / `InteractiveGrid2D` + `CustomCursor` . *Likely* heavy main-thread load on low-end Android (INP risk). **Measure with Lighthouse before optimizing.**
- Observer surface (`useInView` , `LenisProvider` , `Interactive*` , `SpotlightCard`) — audit each `useEffect` for cleanup (flagged target, not a confirmed leak).
- Manual chunking only splits `gsap` / `framer` (`vite.config.ts:30`); `lenis` /Radix/lucide could split further.
- Fonts already use `&display=swap`  .

6. Suggested Tests

- **Unit:** `mail.ts` — `detectProvider` (gmail/outlook/yahoo/unknown/ `a@/no-@`); `buildMailURLs` encoding of `&` , spaces, unicode, emoji.
- **Integration:** contact `onSubmit` — missing date → error; valid → correct `to/subject/body` + `openCompose` called.
- **E2E (Playwright):** every route 200s + zero console errors; contact happy path; theme persists across reload; skip-link focus; 404 renders `NotFoundPage` .
- **Security (CI):** post-deploy header assertion (curl / securityheaders.com).
- **Load:** N/A for static CDN — test edge cache headers instead.

7. Production Readiness Checklist

Item	Status
Type safety (<code>tsc</code>)	 PASS
Error boundary	 PASS (<code>router.tsx</code>)
Skip link / reduced-motion	 PASS
Per-page SEO	 FAIL (home only)
Canonical / sitemap / og:image	 FAIL
Security headers	 FAIL
No secrets/creds in client	 FAIL (admin/1234)
Automated tests / CI	 FAIL
Repo hygiene	 WARN
Lead capture reliability	 WARN (mailto-only)
Brand consistency	 WARN (Orvion/Orivon)

8. Roadmap

1. **Delete** `/login` + **hardcoded creds** (removes P0).
 2. Centralize SEO: per-route head, absolute canonicals, default og:image.
 3. Replace mailto-only contact with a serverless form endpoint (keep compose as fallback).
 4. Clean `reports/` from version control; extend `.gitignore`.
 5. Add Playwright smoke suite + CI gate (lint + typecheck + test).
-

9. Final Verdict

Conditionally production-ready — 68/100. A genuinely well-built static SPA with strong visual engineering and clean, type-safe code. It is *not* the "100M-user, payment-handling" system a generic audit imagines, and was not scored against threats it doesn't have. Fix the one launch blocker (fake login), then close SEO + headers + og:image + tests — those, not exotic vulnerabilities, are what stand between this and a studio site that converts and ranks.

Honesty Notes

- No Lighthouse / device matrix / profiler was run — all performance, CLS, FPS, INP, and observer-leak claims are *Likely/Possible*, not *Verified*.
- Categories with no code surface (payments, JWT, SSRF, DB, upload, GraphQL) are marked *N/A*, not fabricated.